Ransomware Risk Treatment Case Lab: Northbridge Community Health

Name: Adaeze Elizabeth Adeteye **Registration no.:** [ADD REGISTRATION NUMBER]

Source: Health Service Executive, Cyber-attack and HSE response; last reviewed 1 December 2025; accessed 18 October 2026. https://www2.hse.ie/services/cyber-attack/what-happened/

Companion workbook: Northbridge_Risk_Treatment_Workbook.xlsx (register, budget, insurance, decision log, plan). Real HSE facts are tagged F; fictional exercise assumptions are tagged X (brief) or M (mine). Nothing about Northbridge is a fact about HSE.

Task 1. Evidence and risk register

Real HSE fact (official account)	What I take from it for Northbridge
F1: A phishing email reached one user on the HSE network in March 2021. Opening its attachment silently downloaded malware, and the ransomware was triggered in May 2021.	Roughly two months passed between entry and encryption. The warning window existed; what mattered was whether anyone owned it.
F2: The attackers copied information as well as encrypting files. HSE notified 90,000 people, starting in November 2022, and states that no ransom was paid.	Data loss has a long tail (more than a year to notify), and refusing to pay is only viable if recovery works.

Fictional assumptions. From the brief: unused supplier workflow enabled (X2), recovery untested (X3), phishing reports have no escalation owner (X4), essential bookings must continue (X5), prices and policy terms are classroom figures (X6). Mine: one shared environment across the three clinics (M1), role titles as owners (M2), a four-hour recovery target for bookings (M3). Full list on the workbook's Assumptions sheet.

Risk and owner	Asset, threat, weakness	Business impact	L×I	Why I rated it this way
R1 Service disruption Owner: Clinical Operations Director	Asset: Booking and patient-record platform used by all three clinics. Threat: Ransomware encrypts the platform, entering through a phishing attachment as at HSE (F1). Weakness: Recovery has never been tested (X3), so no one can show a backup restores.	Essential bookings stop; paper fallback is a stopgap; patients are delayed or turned away	4×5 = 20 Critical	Likelihood 4: the entry route is ordinary and nothing shows a restore working. Impact 5: essential bookings must continue (X5) and there is no proven fallback. Critical, so it cannot be accepted.
R2 Sensitive-data loss Owner: Data Protection Officer	Asset: Patient health and contact records. Threat: Records are copied out before or during encryption, as HSE's were (F2). Weakness: Account access has never been reviewed and nothing flags bulk copying (my assumption M1).	Patient harm, a notification burden that can run for months, regulator and reputational exposure	3×5 = 15 High	Likelihood 3: needs a foothold plus copying, which my controls would partly hinder once B lands. Impact 5: health data is the worst thing to lose and HSE needed over a year to notify (F2). High, so board escalation.
R3 Unnecessary supplier exposure Owner: IT Manager	Asset: Unused supplier workflow and its connection into Northbridge systems. Threat: Attacker or a compromised supplier uses a pathway nobody is watching. Weakness: The workflow is enabled but unused (X2), so there is no business reason for it to exist.	An avoidable foothold into the network	4×3 = 12 High	Likelihood 4: it is open, idle and unwatched, so misuse would blend in. Impact 3: I cannot yet say what it reaches, so I scored the middle until the review answers that. High, so board escalation.
R4 Delayed detection Owner: IT Manager	Asset: Staff mailboxes and the phishing-reporting route. Threat: A phishing email or early malware sits unnoticed, as it did for about two months at HSE (F1). Weakness: Phishing reports have no escalation owner (X4).	A small compromise turns into an encryption event before anyone acts	4×4 = 16 High	Likelihood 4: reports go nowhere. Impact 4: late detection converts a contained incident into R1 and R2. High, so board escalation.

Likelihood and impact 1-5, multiplied. Low 1-4, Medium 5-9, High 10-16, Critical 17-25 (classroom scales). Critical cannot be accepted; High needs board escalation.

Task 2. Initial treatment portfolio (decision recorded before the change)

ID	Option	Initial decision	Cost	Risks addressed	Why selected or rejected
A	Retire the unused supplier workflow (Avoidance)	Selected	$5,000	R3 (primary); R2, R4	Removes the pathway instead of defending it. Cheapest option and the cleanest way to deal with R3.
B	MFA rollout and account access review (Mitigation)	Selected	$25,000	R2 (primary); R3, R4	Cuts credential misuse and clears dormant and supplier accounts. It is the main lever on R2.
C	Protected backups, restoration tests and recovery plan (Mitigation)	Selected	$30,000	R1 (primary); R2	Only option that addresses the Critical risk. Non-negotiable.
D	Managed detection and incident escalation service (Mitigation)	Not selected	$35,000	R4 (primary); R1, R2	Valuable, but $35,000 does not fit beside B and C. Deferred, with R4 accepted for 90 days (AC-1).
E	Targeted awareness training and reporting process (Mitigation)	Selected	$10,000	R4 (primary); R2	Cheapest fix for the HSE lesson: a phishing report needs an owner and a route.
F	Network segmentation and legacy dependency review (Mitigation)	Not selected	$40,000	R2, R3, R1	Largest and slowest option. Better scoped once A and B show what is connected. Year 2.
G	Illustrative cyber insurance ($25,000 deductible; $250,000 max per covered claim) (Transfer)	Selected	$20,000	Financial impact of R1, R2	Transfer limits the money lost, not the outage. Worth buying at this price once core controls exist.
	Selected total / remaining budget		**$90,000**	**Remaining $10,000 of $100,000**	**Held as unallocated reserve.**

Avoidance and mitigation. A avoids the supplier exposure outright. B, C and E mitigate: B and E lower the chance of a foothold and speed up escalation, C limits the damage if one lands. **Transfer.** Transfer (G) covers part of the money, not the service, and does not remove Northbridge's accountability for patient data. Insurance pays off once a covered loss exceeds the $45,000 of deductible plus premium; the $250,000 cap is used up at a $275,000 loss. Outsourcing or insuring never removes Northbridge's own accountability. **Acceptance.** I accept one risk for a limited time, AC-1: residual R4 (delayed detection) while D waits, owner IT Manager, expiry Fri 12 Feb 2027, approver the Chair of the Board Risk Committee (simulated). I reject accepting R1: it is Critical.

Task 3. Retained financial exposure under Option G

Covered loss	Insurer payment	Retained loss	Premium	Total year-1 outlay	If the claim is excluded
$180,000	min(max(180,000 − 25,000, 0), 250,000) = $155,000	$25,000	$20,000	$45,000	Insurer pays $0; Northbridge bears $180,000, outlay $200,000
$400,000	min(max(400,000 − 25,000, 0), 250,000) = $250,000	$150,000	$20,000	$170,000	Insurer pays $0; Northbridge bears $400,000, outlay $420,000

If a claim is excluded, the insurer pays nothing and Northbridge bears the whole loss plus the premium already spent ($200,000 for a $180,000 loss; $420,000 for a $400,000 loss). That falls on Northbridge's own funds and so on its board; patients carry the service consequences that no payout repairs. The cap is used up at a $275,000 loss, so at $400,000 I retain $150,000 (six times the deductible). Cover beats no cover once a covered loss passes $45,000. These are fictional policy terms; no purchase is being made.

Task 4. Response to the change (restoration test fails; paper holds four hours; B rises to $35,000)

Item	Initial decision	Revised decision
Trigger	Assumption set in the brief.	Restoration test fails; paper bookings hold for four hours; B rises to $35,000.
Portfolio	A, B, C, E, G = $90,000. Reserve $10,000.	A, B, C, E = $80,000. Reserve $20,000.
What changed	-	B +$10,000. G removed from year-1 spend. Reserve doubled and ring-fenced. C's first task is to fix the failed restore. Paper drill added at no cost.
Deferred	D, F.	G (to 15 Dec gate), D (to 12 Feb 2027 review), F (year 2).
Remaining risk owners	R1 Clinical Operations Director; R2 DPO; R3 IT Manager; R4 IT Manager.	Unchanged. R1 now has evidence behind it rather than an assumption.
Needs escalation	R2, R3, R4 (High) and R1 (Critical).	Whether the Board will run for up to 30 days on a known 4-hour continuity limit with the financial tail unfunded (AC-2). Chair of the Board Risk Committee decides.

Why G goes, not something else. I dropped G because a payout arrives after the outage and cannot restore a booking, and four hours of paper is the number that now drives everything. The $20,000 reserve equals the premium: it pays for recovery rework first, and buys insurance at the 15 December gate only if the retest passes. I also do not want to apply for cover while my own test says recovery fails (M4).

Revised portfolio: A $5,000 + B $35,000 + C $30,000 + E $10,000 = $80,000; reserve $20,000 (within the same $100,000). Deferred: D, F, G.

Task 5. 30-day treatment plan (Day 1 Mon 16 Nov 2026; board decision Fri 13 Nov 2026)

#	Action	Opt.	Owner	Cost	Target	Effectiveness test
1	Name the phishing-escalation owner and publish one reporting route	E	IT Manager	within option	Wed 18 Nov	Three seeded test reports reach the owner and are triaged within one working hour.
2	Retire the supplier workflow; supplier confirms removal in writing; review past activity logs	A	IT Manager	$5,000	Fri 20 Nov	Outside connection to the old endpoint is refused; log review shows no unexplained use; written confirmation on file.
3	Targeted training for front-desk, booking and clinical admin staff; reporting process goes live	E	Data Protection Officer	$10,000	Fri 27 Nov	Simulated phishing run: baseline report rate recorded, then at least 70% of target staff report within 24 hours (my target).
4	Paper-booking drill at one clinic; agree what happens after hour four	-	Clinical Operations Director	$0	Fri 27 Nov	Timed drill shows how long paper holds and where it breaks; hour-four triage rule signed off.
5	Root-cause the failed restore, fix it, and set up protected backups	C	IT Manager	$30,000	Fri 4 Dec	Negative test: a normal admin account cannot alter or delete the protected copy.
6	Access review: leavers, shared, dormant and supplier accounts	B	IT Manager (DPO signs off)	$35,000	Fri 4 Dec	No dormant account over 90 days, no shared admin account; DPO samples 15 accounts.
7	Timed full restore of bookings and patient records to a clean environment, witnessed	C	Clinical Operations Director	within option	Fri 11 Dec	Bookings usable within 4 hours, records complete to the last backup (24 hours or less), witness signs. A fail keeps R1 Critical.
8	Enforce MFA on admin, remote and email access	B	IT Manager	within option	Tue 15 Dec	Identity report shows 100% enforcement; five sign-in attempts without the second factor all fail.
9	Board checkpoint: release the reserve and review AC-2	G / C	Finance Director	$0	Tue 15 Dec	Bind G only if the retest passed and the DPO has reviewed the terms; otherwise the reserve stays for recovery rework.
	Total committed (reserve $20,000 held separately)			**$80,000**		

An untested control is not counted as working: each residual score below is credited only once its test passes.

Risk	Initial	Proposed residual	Assumption behind the residual
R1 Service disruption	20 Critical	3×4 = 12 High	Credited only after the witnessed restore passes the 4-hour target. Until then I carry R1 at 20, Critical.
R2 Sensitive-data loss	15 High	2×5 = 10 High	B, E and A lower likelihood. Without D or F nothing detects copying or limits spread, so it stays High.

Risk	Initial	Proposed residual	Assumption behind the residual
R3 Unnecessary supplier exposure	12 High	2×3 = 6 Medium	Low only once the supplier confirms removal in writing and logs show no unexplained use. Unknown legacy links stay until F's review, so I hold it at Medium.
R4 Delayed detection	16 High	3×4 = 12 High	E gives reports an owner and a route but no 24/7 monitoring. Still High, so I ask the board to accept it for 90 days (AC-1).

Acceptances. AC-1: R4 residual, owner IT Manager, expiry Fri 12 Feb 2027, trigger: any phishing report not triaged within one working hour, a failed reporting drill, a suspected compromise, or an insurer or regulator asking for 24/7 monitoring; approver Chair of the Board Risk Committee (simulated). AC-2: temporary retention of the unfunded financial tail (not R1), owner Finance Director, expiry Tue 15 Dec 2026, trigger: restore retest result on 11 Dec, insurer terms reviewed by the DPO, or any incident before the gate; same approver. **Escalation:** the board decides AC-2, and R2 to R4 are High.

Board memo

To: Board of Directors, Northbridge Community Health **From:** Adaeze Elizabeth Adeteye **Date:** 13 November 2026 **Subject:** Ransomware risk treatment: decision requested

Decision requested. I ask the Board to approve $80,000 of the $100,000 first-year budget and ring-fence the other $20,000. The $80,000 funds A (retire the supplier workflow, $5,000), B (MFA and access review, $35,000), C (protected backups, restoration and recovery plan, $30,000) and E (targeted training and reporting, $10,000).

Why. Our restoration test failed and paper bookings last only four hours. Booking continuity comes first, so I have deferred cyber insurance (G, $20,000): a payout cannot reopen a clinic. The reserve pays for recovery rework first. If the retest passes by 11 December, it may buy insurance at the 15 December checkpoint.

Service-continuity priorities. 1. A witnessed restore within four hours. 2. A paper-booking drill and a triage rule beyond hour four. 3. Close the unused supplier pathway this month.

Unresolved risks. R1 service disruption stays Critical (20) until the retest passes; it cannot be accepted. R2 data loss (10) and R4 delayed detection (12) stay High. I ask the Board to accept R4 until 12 February 2027 while managed detection ($35,000) waits; the IT Manager owns it. Deferring insurance leaves the financial tail unfunded until 15 December; the Finance Director owns that, and the Chair of the Board Risk Committee must approve it. Even insured, a $400,000 loss would leave us carrying $150,000, and accountability for patient data stays with us.

Memo length: 243 words. Costs, policy terms and the changed circumstances are fictional exercise assumptions; the phishing-to-ransomware timeline and the data-copying facts are from the HSE account.